Simulasi Serangan DDoS

Aaron Austen 2702224446 | Samuel Yedija Purnomo 2702347963

Bagian 1: Konsep Dasar

Memahami Apa, Mengapa, dan Bagaimana DDoS Terjadi

Apa Itu DDoS?

Definisi

Ini adalah serangan 'brute force' pada ketersediaan. Tujuannya bukan untuk mencuri data, melainkan untuk melumpuhkan layanan dengan mengirimkan 'banjir' permintaan palsu dari berbagai komputer di seluruh dunia, sehingga permintaan sah dari pengguna asli tidak bisa masuk.

Tipe: Volumetrik

Fokus serangan ini adalah menghabiskan 'pipa' jaringan. Bayangkan sebuah jalan tol. Serangan ini mengirimkan jutaan mobil mainan ke jalan tol tersebut, sehingga mobil sungguhan tidak bisa lewat. Contohnya adalah UDP Flood atau ICMP Flood.

Tipe: Aplikasi (Layer 7)

Serangan yang lebih 'halus' namun sangat efektif. Ini tidak menargetkan pipa jaringan, tapi langsung ke 'pintu' aplikasinya (misal, web server). Ia mengirimkan permintaan yang terlihat normal (seperti memuat halaman) tapi dalam jumlah besar, menghabiskan CPU dan memori server. Ini yang akan kita simulasikan.

Bagaimana DDoS Bekerja? (Botnet)

Serangan DDoS yang efektif hampir tidak mungkin dilakukan dari satu komputer penyerang. Untuk mencapai skala 'terdistribusi', peretas mengandalkan **Botnet**.

1. Infeksi: Melalui malware, phising, atau kerentanan, peretas menginfeksi ribuan perangkat di seluruh dunia. Perangkat ini (komputer, HP, router, bahkan CCTV) menjadi 'Zombie' tanpa disadari pemiliknya.

2. Perintah: Seluruh 'Zombie' ini secara diam-diam melapor ke server pusat yang disebut Command & Control (C&C). Dari sinilah sang 'Bot-Herder' (peretas) mengelola pasukannya.

3. Serangan: Dengan satu perintah, peretas mengarahkan seluruh Botnet untuk menyerang satu target secara serentak. Korban tidak melihat serangan dari satu IP, tapi dari ribuan IP berbeda, membuatnya sangat sulit diblokir.

Motivasi di Balik Serangan

Pemerasan (Ransom)

Skenario paling umum. Penyerang melumpuhkan layanan dan mengirim email: 'Bayar kami X Bitcoin dalam 24 jam, atau serangan akan berlanjut dan semakin besar.'

Persaingan Bisnis

Perusahaan A menyewa peretas untuk menyerang Perusahaan B selama peluncuran produk baru atau musim liburan, menyebabkan pelanggan beralih ke layanan Perusahaan A yang 'stabil'.

Hacktivism

Kelompok aktivis yang tidak setuju dengan kebijakan pemerintah atau perusahaan dapat menggunakan DDoS sebagai bentuk protes digital untuk menyuarakan pesan mereka.

Mengapa DDoS Sangat Berbahaya?

- **Kerugian Finansial Langsung:** Setiap detik layanan tidak aktif adalah kerugian pendapatan langsung. Bagi e-commerce, ini berarti kehilangan penjualan. Bagi layanan game, ini kehilangan pemain. Bagi bank, ini menghentikan transaksi.
- **Kerusakan Reputasi:** Ini adalah dampak jangka panjang. Pengguna yang frustrasi karena tidak bisa mengakses layanan akan menganggap platform tersebut tidak aman atau tidak stabil, dan mungkin akan pindah ke pesaing secara permanen.
- **Kedok Aktivitas Lain:** Ini adalah taktik paling licik. Saat seluruh tim keamanan sibuk menangani 'kebakaran' (DDoS), peretas secara diam-diam menyusup ke database melalui celah lain untuk mencuri data pelanggan atau rahasia perusahaan.
- **Gangguan Layanan Publik:** Dampaknya bisa sangat serius jika targetnya adalah infrastruktur kritis, seperti melumpuhkan sistem pendaftaran rumah sakit, layanan perbankan nasional, atau jaringan komunikasi pemerintah.

Jenis Serangan DDoS

Layer 7 Attack (Application)

Protocol Attack

Volumetric Attack

Spoofing, Flooding, Amplification

Mitigasi & Tanggapan Terhadap DoS & DDoS

- **Intrusion Prevention System:** Metode untuk mencegah serangan cyber, terutama DDoS dan DoS. Sehingga, IPS biasa dipakai untuk mendeteksi terlebih dahulu sebelum masuk ke network secara real-time.

- **Intrusion Detection System:** Real-time detection yang ditempatkan di dekat firewall. Tujuan nya adalah untuk menghapus/menutup koneksi jika terjadi serangan atau setelah mendeteksi traffic tidak lazim. IDS bekerja secara real-time setelah melewati IPS, berbeda dengan IPS yang mencegah masuknya traffic menurigakan.

Jenis jenis IPS & IDS

Anomaly-based

mendeteksi pola lalu lintas normal contoh sehari hari jumlah pengakses website kita 1000 orang. Pada suatu hari melonjak menjadi 30.000

signature-based

Memiliki database dari serangan serangan yang sudah dikenal

Stateful Protocol Analysis

memahami cara kerja protokol seharusnya berlaku.

Bagian 2: Simulasi Kami

Membangun Skenario Serangan DOS di Lingkungan VM

Arsitektur Simulasi

Kami menyiapkan laboratorium virtual yang aman dan terisolasi. Penggunaan Virtual Machine sangat penting agar serangan tidak 'bocor' dan berdampak pada jaringan utama (jaringan produksi atau internet).

VM Korban (Victim):
Mensimulasikan server target. VM ini menjalankan OS Linux (Ubuntu Server) dan layanan web server Apache2 yang dikonfigurasi untuk menayangkan halaman HTML statis.

VM Penyerang (Attacker):
Mensimulasikan 'Zombie' atau penyerang. VM ini menjalankan OS *pentesting* (Ubuntu Linux) yang sudah dilengkapi dengan berbagai alat serangan, termasuk yang akan kita gunakan.

Tutorial Setup: Lingkungan

1. VM Korban

Membuat VM baru, menginstal OS Ubuntu Dekstop. Setelah itu, menginstal paket web server Apache2 menggunakan `apt install apache2`.

2. Web Page

Membuat file HTML dasar (`index.html`) sebagai target serangan. File ini kemudian ditempatkan di direktori web root Apache.

3. VM Penyerang

Membuat VM kedua dan menginstal Kali Linux atau Ubuntu. Ubuntu dipilih karena mudah untuk simulasi ini.

4. Jaringan

Mengkonfigurasi pengaturan jaringan kedua VM (misal, di VirtualBox) agar berada di 'Jaringan Internal'. Ini penting agar mereka bisa saling berkomunikasi tapi terisolasi dari luar.

Tutorial Setup: Konfigurasi Server Korban

File HTML: Kami tidak memerlukan web yang kompleks. Cukup file `index.html` sederhana.

Contoh: ``

index.html
/var/www/DummyTestss

APIcall.php | index.html

```
:script>
    async function loadWeather() {
        const res = await fetch('APIcall.php');
        const data = await res.json();

        document.getElementById('weather').innerHTML = `
            <h2>${data.city}</h2>
            <p><strong>${data.temperature_celsius}°C</strong
```

Web Server: Di VM Korban, kami menjalankan `sudo apt update` dan `sudo apt install apache2` untuk menyiapkan layanan web.

Lokasi File: Kami memindahkan atau membuat file `index.html` di lokasi default Apache, yaitu `/var/www/html/`, menggantikan halaman default Apache.

Verifikasi: Kami mendapatkan IP VM Korban (misal, `192.168.56.101`). Dari browser di VM Penyerang, kami mengakses IP tersebut untuk memastikan halaman 'Server Uji Coba' tampil. Ini adalah kondisi 'normal' sebelum serangan.

local.rules
/etc/snort/rules (Administrator)

local.rule | snort.conf | commndSno | dumtes.conf | dos.rules

```
#alert tcp any any -> 192.168.1.14 any (msg:"Attack attempt";
content:"GET"; http_method; flags:*SA; flow:stateless;
detection_filter: track by_src, count 30 , seconds 10; sid:
1000007;)

#alert ip any any -> 192.168.1.14 any (msg:"IP Request too many";
detection_filter: track by_src, count 400 , seconds 5; sid:
1000008;)

reject ip any any -> 192.168.1.14 any ( msg:"Too much request,
rejected "; detection_filter: track by_src, count 500 , seconds 5;
sid:1000009;)
```

snort.conf
/etc/snort (Administrator)

local.rules | snort.con | commndSno | dumtes.conf | dos.rules

```
# /etc/snort/snort.debian.conf configuration file
#
ipvar HOME_NET 192.168.1.0/24

# Set up the external network addresses. Leave as "any" in most
situations
ipvar EXTERNAL_NET any
# If HOME_NET is defined as something other than "any",
alternative, you can
# use this definition if you do not want to detect attacks from
your internal
# IP addresses:
#ipvar EXTERNAL_NET !$HOME_NET
```

Alat Serangan yang Digunakan

Volumetrik / Flooding

Volumetrik adalah istilah yang berkaitan dengan volume atau kuantitas. Dalam konteks DDoS, ini merujuk pada serangan yang bertujuan menghabiskan seluruh volume bandwidth (kapasitas internet) target. Penyerang membanjiri server dengan lalu lintas sampah dalam jumlah besar (diukur dalam Gbps/Tbps) sehingga lalu lintas pengguna yang sah tidak bisa masuk, sama seperti menyebabkan kemacetan total di jalan tol.

Alat Serangan yang Digunakan

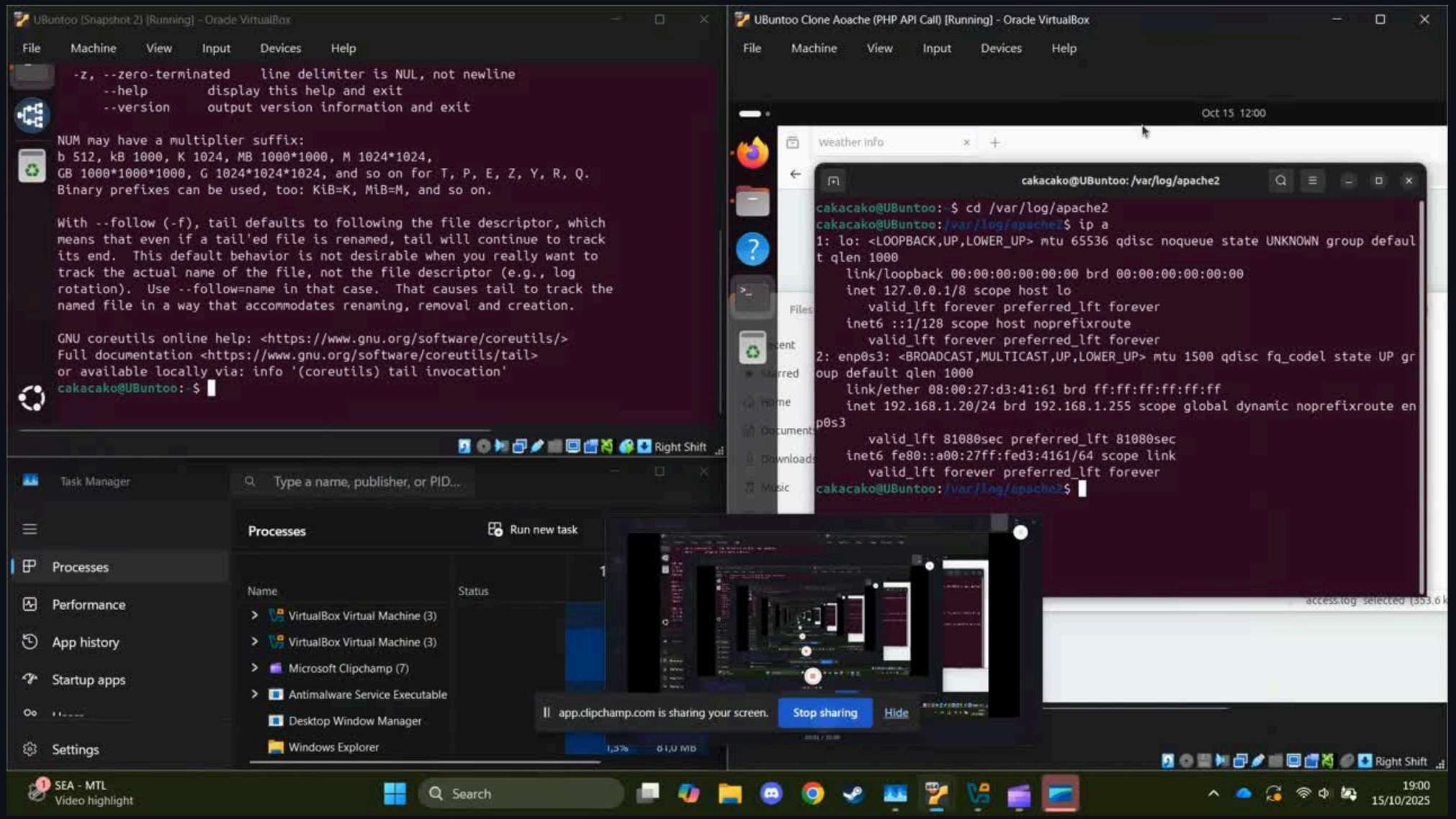
Slowloris

Berbeda dengan 'banjir' data (Volumetrik), Slowloris bekerja secara perlahan. Ia membuka ratusan koneksi ke server Apache. Triknya adalah: ia mengirimkan data permintaan HTTP, tapi sangat lambat (byte per byte) dan tidak pernah menyelesaikannya. Apache akan terus menunggu koneksi ini selesai, dan dalam hitungan detik, semua slot koneksi (worker) di server menjadi penuh dan tidak bisa lagi menerima koneksi baru dari pengguna sah.

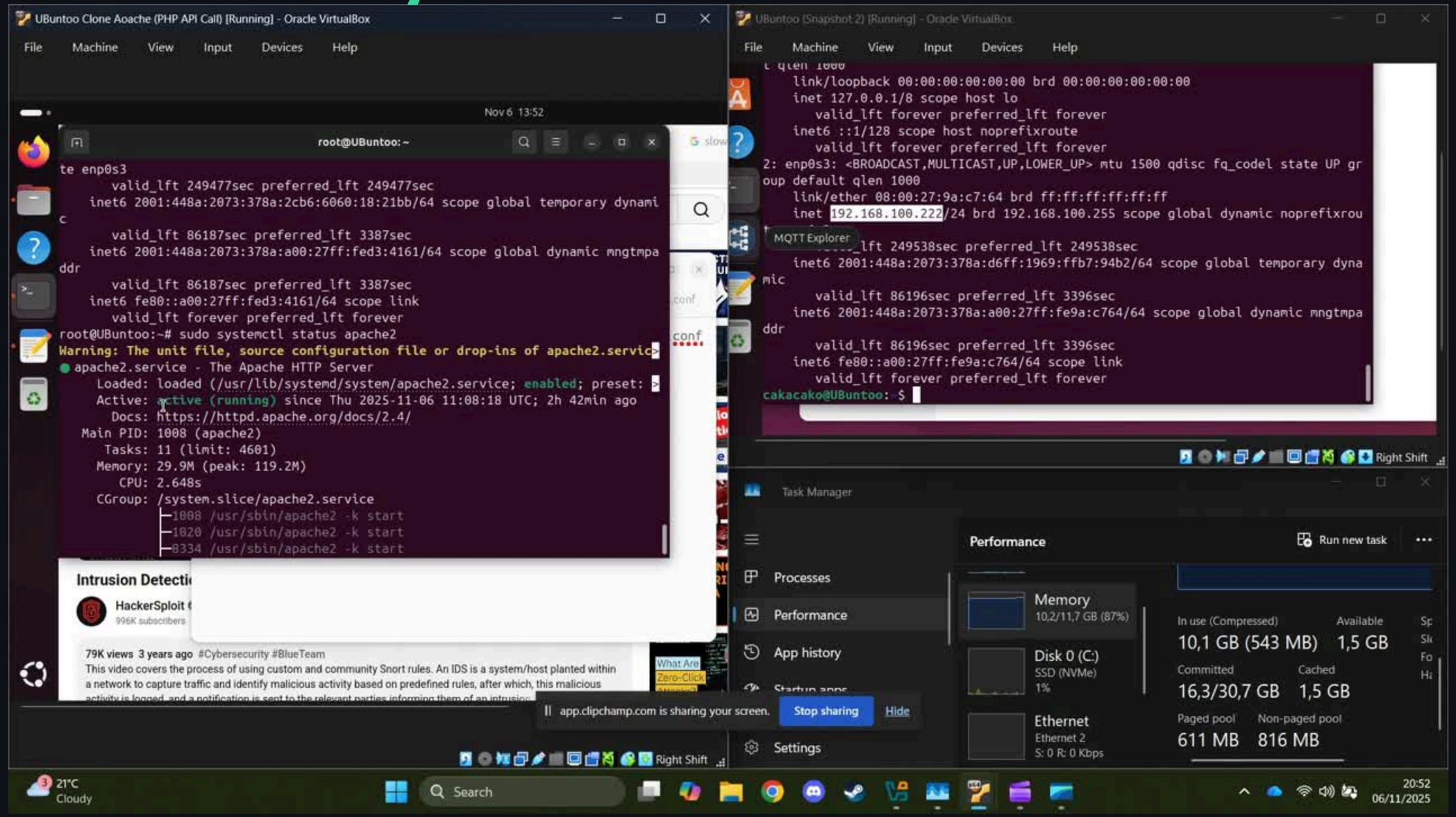
Bagian 3: Eksekusi & Hasil

Melihat Respon Server Selama Serangan

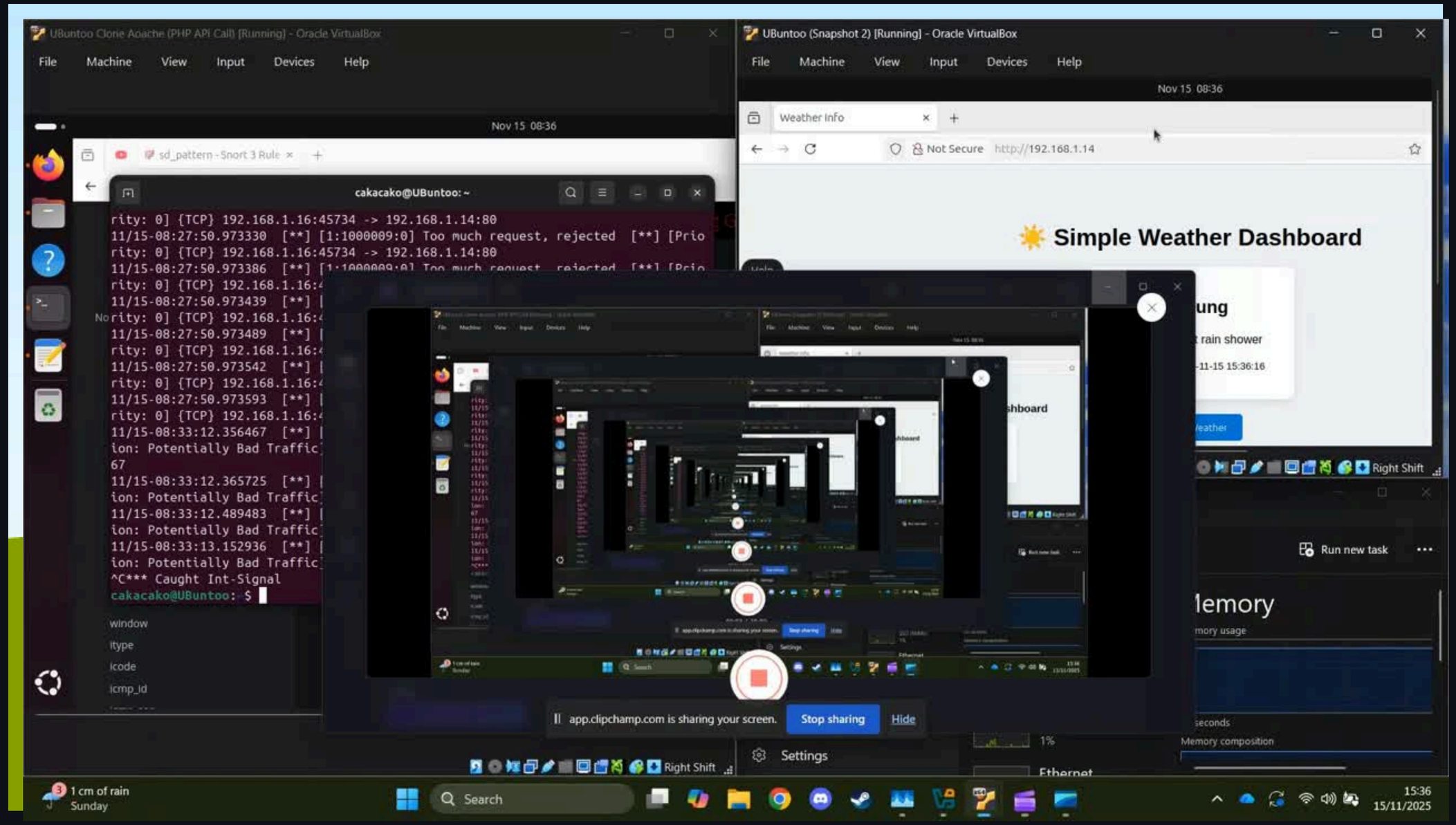
Simulasi normal



Simulasi Alert Only



IDS & IPS


UBuntoo Clone Apache (PHP API Call) [Running] - Oracle VirtualBox
File Machine View Input Devices Help
Nov 15 08:36
sd_pattern - Snort 3 Rule
cakacako@UBuntoo: ~
rity: 0] {TCP} 192.168.1.16:45734 -> 192.168.1.14:80
11/15-08:27:50.973330 [**] [1:1000009:0] Too much request, rejected [**] [Prio
rity: 0] {TCP} 192.168.1.16:45734 -> 192.168.1.14:80
11/15-08:27:50.973386 [**]
11/15-08:27:50.973439 [**]
11/15-08:27:50.973489 [**]
11/15-08:27:50.973542 [**]
11/15-08:27:50.973593 [**]
11/15-08:33:12.356467 [**]
ion: Potentially Bad Traffic
67
11/15-08:33:12.365725 [**]
ion: Potentially Bad Traffic
11/15-08:33:12.489483 [**]
ion: Potentially Bad Traffic
11/15-08:33:13.152936 [**]
ion: Potentially Bad Traffic
^C*** Caught Int-Signal
cakacako@UBuntoo: $
window
itype
icode
icmp_id
UBuntoo (Snapshot 2) [Running] - Oracle VirtualBox
File Machine View Input Devices Help
Nov 15 08:36
Weather Info
Not Secure http://192.168.1.14
Simple Weather Dashboard
ung
rain shower
-11-15 15:36:16
Right Shift
Run new task
lemory
mory usage
seconds
Memory composition
app.clipchamp.com is sharing your screen.
Stop sharing
Hide
Settings
Right Shift
1 cm of rain
Sunday
Search
15:36
15/11/2025

Tail access log

Tail access log adalah tindakan untuk memantau server secara real-time. Ini dilakukan dengan perintah tail -f pada file access.log (catatan aktivitas server). Perintah ini menampilkan setiap kunjungan baru ke server saat itu juga, memungkinkan administrator melihat "banjir" lalu lintas secara langsung saat serangan DDoS volumetrik terjadi.

Bagaimana Cara Mencegah Ini? (Mitigasi)

Layanan Scrubbing & CDN

Ini adalah solusi paling umum untuk serangan volumetrik. Semua trafik dialihkan ke 'pusat pembersihan' (Scrubbing Center) milik provider seperti Cloudflare atau Akamai. Mereka memiliki kapasitas bandwidth raksasa untuk menyerap serangan dan menggunakan filter canggih untuk memisahkan trafik palsu, sehingga hanya trafik pengguna sah yang sampai ke server Anda.

Jenis - Jenis Layanan Scrubbing

Always-On

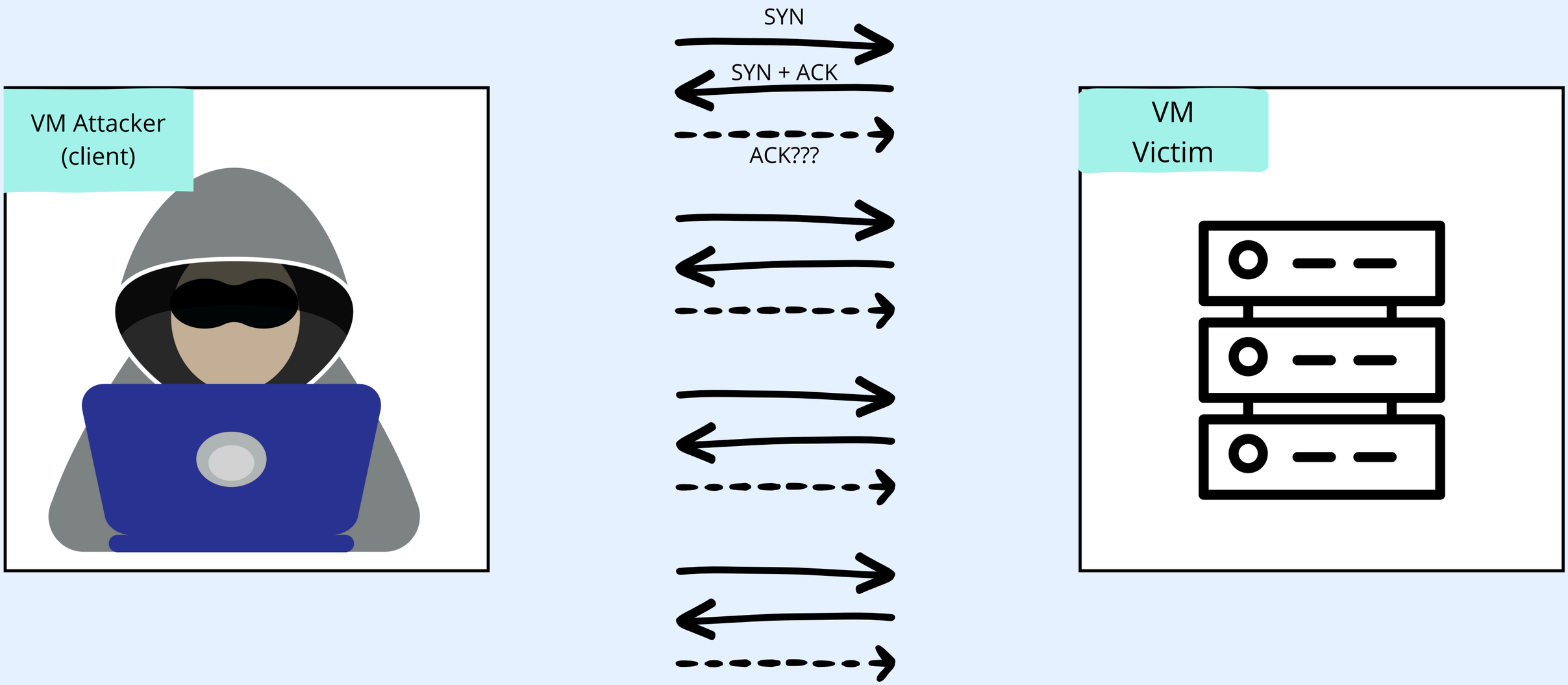
Selalu aktif mendeteksi apakah ada sesuatu yang janggal.

On-Demand

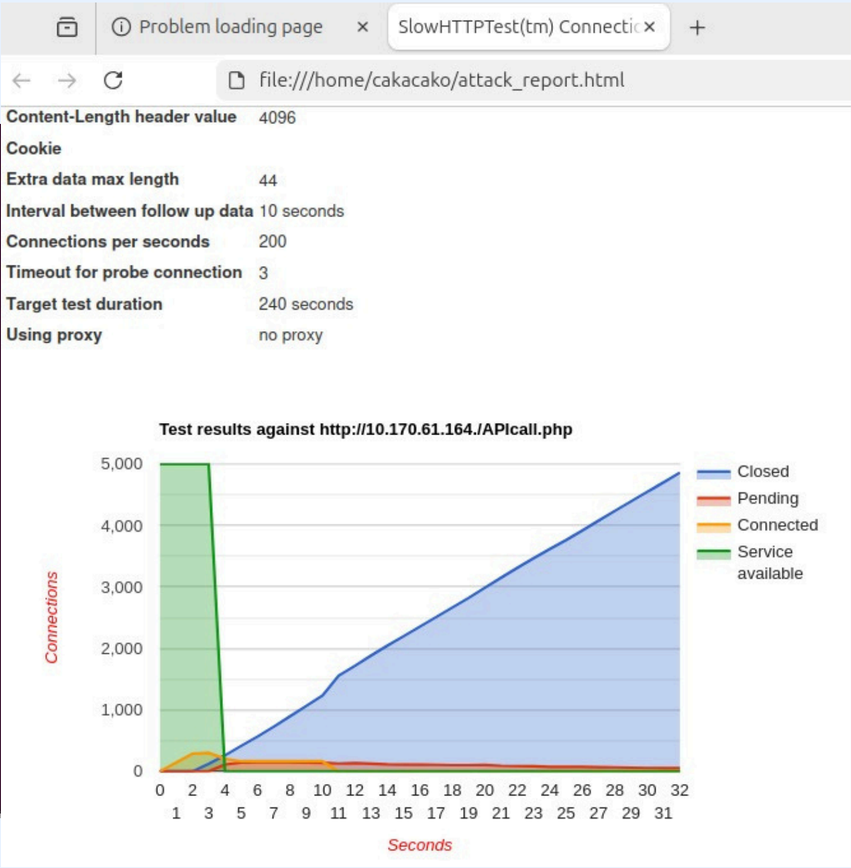
diatur manual atau otomatis saat serangan terdektesi

Konfigurasi Server (WAF & Rate Limit)

Untuk serangan Layer 7 (seperti Slowloris), WAF lebih efektif. WAF dapat mendeteksi pola aneh (misal, koneksi yang terlalu lambat). *Rate Limiting* juga penting, yaitu membatasi jumlah koneksi dari satu IP. Misal, jika satu IP mencoba membuka 1000 koneksi, sistem akan otomatis memblokirnya setelah 50 koneksi.


VM Attacker
(client)
SYN
SYN + ACK
ACK???
VM
Victim

```
cakacako@UBuntoo:~$ sudo fail2ban-client status snort-slowloris
Status for the jail: snort-slowloris
Status for the jail: snort-slowloris
|- Filter
|   |- Currently failed: 0
|   |- Total failed:     9636
|   `- File list:        /var/log/snort/alert
`- Actions
    |- Currently banned: 1
    |- Total banned:     1
    `- Banned IP list:   10.170.61.244
Status: command not found
cakacako@UBuntoo:~$
```



UBuntoo Clone Aoache (PHP API Call) [Running] - Oracle VirtualBox

File Machine View Input Devices Help

Dec 14 08:06

How To Protect SSH with | Fail2ban - Community He | Developing Filters — Fai | Weather Info

http://localhost

cakacako@UBuntoo: ~

```
     Active: active (running) since Fri 2025-12-12 17:01:01 UTC; 1 day 14h ago
       Docs: man:fail2ban(1)
   Main PID: 12970 (fail2ban-server)
      Tasks: 7 (limit: 3469)
     Memory: 112.9M (peak: 113.1M)
        CPU: 10min 42.360s
     CGroup: /system.slice/fail2ban.service
             └─12970 /usr/bin/python3 /usr/bin/fail2ban-server -xf start

Dec 12 17:01:01 UBuntoo systemd[1]: Started fail2ban.service - Fail2Ban Service.
Dec 12 17:01:01 UBuntoo fail2ban-server[12970]: 2025-12-12 17:01:01,404 fail2ba
Dec 12 17:01:01 UBuntoo fail2ban-server[12970]: Server ready

cakacako@UBuntoo:~$ sudo systemctl restart fail2ban
cakacako@UBuntoo:~$ sudo systemctl status fail2ban.service
● fail2ban.service - Fail2Ban Service
     Loaded: loaded (/usr/lib/systemd/system/fail2ban.service; enabled; preset:
     Active: active (running) since Sun 2025-12-14 07:50:12 UTC; 5min ago
       Docs: man:fail2ban(1)
   Main PID: 14131 (fail2ban-server)
      Tasks: 7 (limit: 3469)
     Memory: 24.5M (peak: 27.1M)
        CPU: 30.510s
     CGroup: /system.slice/fail2ban.service
```

UBuntoo [Snapshot 3 mqtt] [Running] - Oracle VirtualBox

File Machine View Input Devices Help

Dec 14 08:06

Weather Info | SlowHTTPTest(tm) Connecti

Not Secure http://10.170.61.164

Simple Weather Dash

Bandung

26.5°C — Light rain shower

Server Time: 2025-12-14 15:05:00

Refresh Weather

Right Shift

27°C Mostly cloudy

Search

15:06 14/12/2025

Kesimpulan

Simulasi di lingkungan VM yang terkendali ini berhasil mendemonstrasikan bagaimana serangan Layer 7 (Slowloris) dapat secara efektif melumpuhkan web server Apache. Bukti utamanya adalah kegagalan total koneksi dari pengguna sah untuk mengakses web (timeout).

Memahami cara kerja, vektor, dan dampak dari serangan ini adalah langkah pertama dan paling krusial sebelum kita dapat merancang, mengkonfigurasi, dan menerapkan langkah-langkah mitigasi yang efektif di dunia nyata.

Q&A

Terima Kasih

Apakah ada pertanyaan?